

Documentation : Audit de sécurité Active Directory (SCRIBE-AD) avec PingCastle.

1. Présentation de l'outil

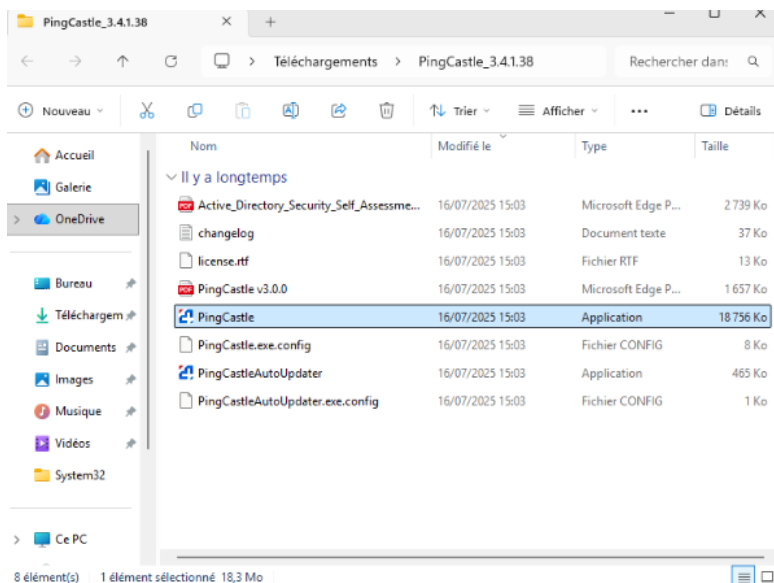
PingCastle est un outil de référence pour auditer la sécurité d'un domaine Active Directory (AD). Il évalue le niveau de risque global et détaille les vulnérabilités par catégories afin de proposer un plan d'action correctif.

2. Préparation et Lancement

L'outil se présente sous la forme d'une archive contenant un exécutable Windows. Il doit être lancé depuis un poste joint au domaine (ex: Windows 11) avec des privilèges d'administration pour un scan complet.

Procédure de lancement :

1. **Extraction** : Décompressez l'archive PingCastle_3.4.1.38.zip.
2. **Exécution** : Lancez le programme via le fichier PingCastle.exe.



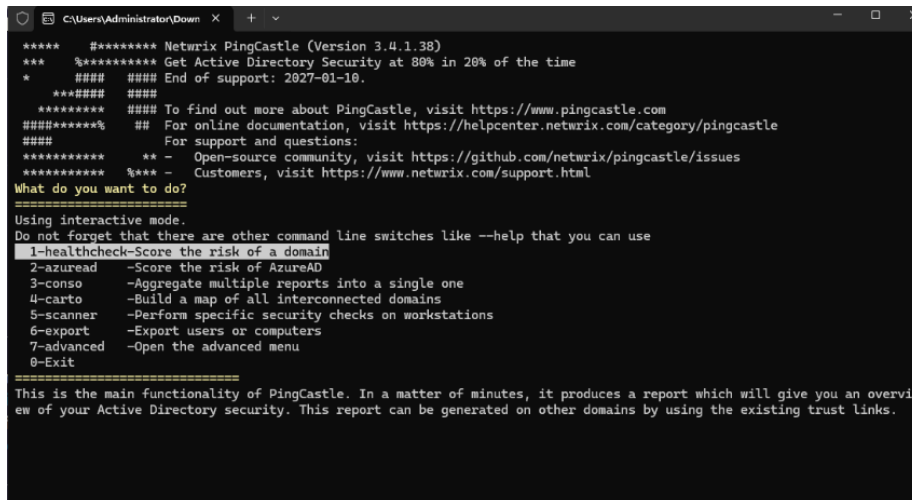
3. Configuration du Scan (Interactif)

Une fois lancé, l'outil propose un menu interactif dans une console. Voici les étapes à suivre selon vos captures :

Étape 1 : Choix de la fonctionnalité

Sélectionnez l'option principale pour évaluer le risque du domaine.

- **Action** : Tapez 1
- **Commande** : 1-healthcheck-Score the risk of a domain



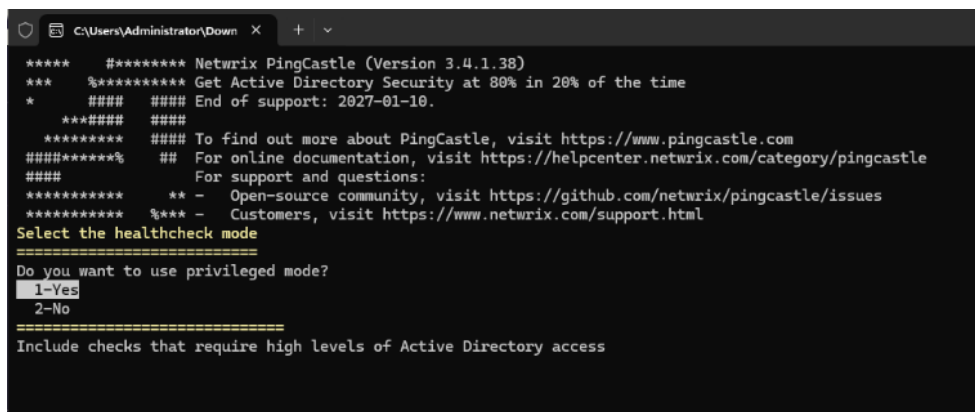
```
***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
#####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html

What do you want to do?
=====
Using interactive mode.
Do not forget that there are other command line switches like --help that you can use
1-healthcheck-Score the risk of a domain
2-azuread -Score the risk of AzureAD
3-conso -Aggregate multiple reports into a single one
4-carto -Build a map of all interconnected domains
5-scanner -Perform specific security checks on workstations
6-export -Export users or computers
7-advanced -Open the advanced menu
0-Exit
=====
This is the main functionality of PingCastle. In a matter of minutes, it produces a report which will give you an overview of your Active Directory security. This report can be generated on other domains by using the existing trust links.
```

Étape 2 : Mode de privilèges

Pour obtenir tous les détails techniques, activez le mode privilégié.

- **Action** : Tapez 1
- **Commande** : 1-Yes (Include checks that require high levels of Active Directory access)



```
***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
#####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html

Select the healthcheck mode
=====
Do you want to use privileged mode?
1-Yes
2-No
=====
Include checks that require high levels of Active Directory access
```

Étape 3 : Sélection du domaine

Spécifiez le domaine à analyser. Par défaut, l'outil détecte celui de votre session.

- **Action** : Appuyez sur **Entrée** pour valider le domaine par défaut.
- **Cible** : scribe.local

```

***** #***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
#####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
##### ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html
Select a domain or server
=====
Please specify the domain or server to investigate (default:scribe.local)

```

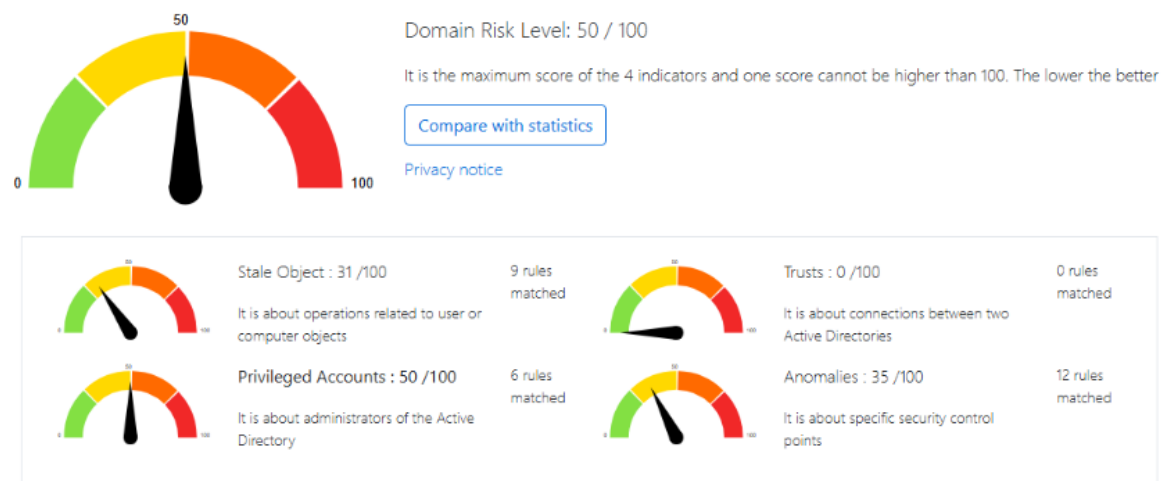
```

##### ##### To find out more about PingCastle, visit https://www.pingcastle.com
***** ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html
Select a domain or server
=====
Please specify the domain or server to investigate (default:scribe.local)

Free Edition of PingCastle - Not for commercial use
Starting the task: Perform analysis for scribe.local
[15:04:47] Getting domain information (scribe.local)
Performance warning: using LDAP instead of ADWS
[15:05:05] Gathering general data
[15:05:06] Gathering user data
[15:05:06] Gathering computer data
[15:05:06] Gathering trust data
[15:05:06] Gathering privileged group and permissions data
[15:05:06] - Initialize
[15:05:06] - Searching for critical and infrastructure objects
[15:05:07] - Collecting objects - Iteration 1
[15:05:07] - Collecting objects - Iteration 2
[15:05:07] - Collecting objects - Iteration 3
[15:05:07] - Collecting objects - Iteration 4
[15:05:07] - Collecting objects - Iteration 5
[15:05:07] - Completing object collection
[15:05:07] - Export completed
[15:05:07] Gathering delegation data

```

Indicators



Domain Risk Level : 50 / 100. Le score global reste identique au précédent, plaçant le domaine à la frontière exacte de la zone orange. Cela confirme une exposition modérée mais réelle, où des failles structurelles attendent d'être corrigées pour ramener l'annuaire dans une zone de sécurité acceptable.

- **Indicateur le plus critique : Privileged Accounts (50 / 100).** C'est désormais le point le plus sensible avec **6 règles détectées**. Ce score élevé sur les comptes à hauts privilèges est préoccupant : il suggère une gestion des administrateurs trop permissive, un manque de protection sur les délégations de droits, ou des comptes sensibles dont les mots de passe n'ont pas été renouvelés récemment.

- **Anomalies (35 / 100)** : Bien qu'en baisse par rapport à votre exemple de référence, cet indicateur déclenche encore **12 règles**. Il met en lumière des configurations techniques non optimales et des écarts de sécurité spécifiques au niveau des protocoles de l'annuaire qui pourraient être exploités pour des mouvements latéraux.
- **Stale Objects (31 / 100)** : Avec **9 règles identifiées**, l'hygiène de l'Active Directory montre des signes de négligence. Des objets obsolètes (comptes ou machines inactifs) polluent l'annuaire, ce qui facilite la tâche d'un attaquant cherchant à passer inaperçu ou à maintenir une persistance sur le réseau.
- **Trusts (0 / 100)** : Ce point est parfait avec **0 règle détectée**. Aucune relation d'approbation avec des domaines externes ne vient affaiblir la sécurité de votre forêt locale pour le moment.

Stale Objects	Privileged accounts	Trusts	Anomalies
Inactive user or computer	Account take over	Old trust protocol	Audit
Network topography	ACL Check	SID Filtering	Backup
Object configuration	Admin control	SIDHistory	Certificate take over
Obsolete OS	Control paths	Trust impermeability	Golden ticket
Old authentication protocols	Delegation Check	Trust inactive	Local group vulnerability
Provisioning	Irreversible change	Trust with Azure	Network sniffing
Replication	Privilege control		Pass-the-credential
Vulnerability management	Read-Only Domain Controllers		Password retrieval
			Reconnaissance
			Temporary admins
			Weak password

Legend:

- score is 0 - no risk identified
- score is 0 - no risk identified but some improvements detected
- score between 1 and 10 - a few actions have been identified
- score between 10 and 30 - rules should be looked with attention
- score higher than 30 - major risks identified

Le code couleur de PingCastle est simple : **Orange** signifie que les règles doivent être examinées avec attention (score entre 10 et 30), et **Jaune** indique quelques actions identifiées.

Stale Objects



Stale Objects : 31 /100

It is about operations related to user or computer objects

Stale Objects rule details [9 rules matched on a total of 56]

The LAN Manager Authentication Level allows the use of NTLMv1 or LM.	+ 15 Point(s)
Non-admin users can add up to 10 computer(s) to a domain	+ 10 Point(s)
The subnet declaration is incomplete [2 IP of DC not found in declared subnets]	+ 5 Point(s)
Number of accounts which have never expiring passwords: 5	+ 1 Point(s)
The functional level is below Windows Server 2012 R2.	Informative rule
Some script extensions used in phishing can be directly run by double clicking on it	Informative rule
Not all possible Defender ASR mitigations are in Block or Warn mode	Informative rule
It is possible for scripts engine used by hackers to connect directly to the Internet	Informative rule
The GPO are not pushing recommended configuration for Terminal Services	Informative rule

Analyse détaillée de mes règles "Stale Objects"

Sur mon environnement Samba-AD, j'ai identifié les vulnérabilités suivantes qui impactent mon score d'hygiène :

- **Usage de NTLMv1 ou LM autorisé (+15 points)** : Mon niveau d'authentification LAN Manager permet encore l'utilisation de protocoles obsolètes. C'est ma faille la plus critique ici, car elle expose le domaine à des attaques par interception de hashes facilement cassables.
- **Ajout de machines par des non-admins (+10 points)** : Par défaut, un utilisateur standard peut encore joindre jusqu'à 10 ordinateurs au domaine. Cela rejoint mon constat de la semaine 2 sur le MAQ (Machine Account Quota) qu'il va falloir que je ramène à 0 pour sécuriser le périmètre.
- **Déclaration de sous-réseau incomplète (+5 points)** : Le rapport indique que 2 IP de mes contrôleurs de domaine ne sont pas trouvées dans les sous-réseaux déclarés. Cela peut créer des instabilités dans la localisation des services par mes clients Windows 11.
- **Comptes avec mots de passe n'expirant jamais (+1 point)** : J'ai détecté 5 comptes dont le mot de passe n'expire jamais. C'est un risque d'hygiène classique : si l'un de ces comptes est compromis, l'attaquant garde un accès persistant sans limite de temps.
- **Niveau fonctionnel inférieur à 2012 R2 (Information)** : Comme sur mon audit UCS précédent, je constate que Samba limite mon niveau fonctionnel. C'est une dette technique connue qui m'empêche d'activer certaines protections Kerberos récentes.
- **Extensions de scripts dangereuses (Information)** : Le système autorise l'exécution directe de certaines extensions par double-clic. C'est un vecteur de phishing que je devrai durcir via une GPO de restriction logicielle.
- **Mises à jour de Defender ASR (Information)** : Les règles de réduction de la surface d'attaque (ASR) de Windows Defender ne sont pas toutes en mode "Blocage" ou "Avertissement". Mon durcissement des postes clients est donc encore incomplet.

- **Moteur de scripts accessible à Internet (Information)** : Il existe une possibilité pour les moteurs de scripts utilisés par des attaquants de se connecter directement à Internet depuis mon réseau. Je devrai vérifier mes règles de pare-feu sortantes.
- **Configuration des services de terminaux (Information)** : Mes GPO ne déploient pas encore les recommandations de sécurité Microsoft pour les accès à distance (RDP), ce qui laisse une marge de manœuvre pour des compromissions de sessions.

Privileged Accounts



Privileged Accounts : 50 / 100
It is about administrators of the Active Directory

Privileged Accounts rule details [6 rules matched on a total of 46]

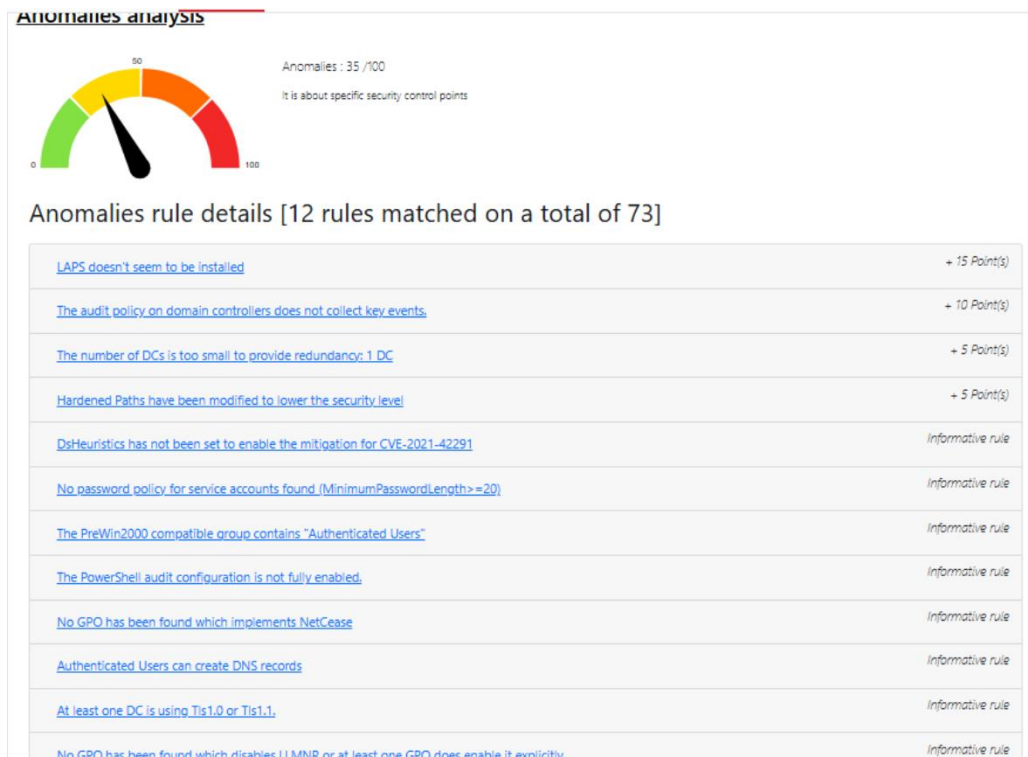
Presence of Admin accounts which do not have the flag "This account is sensitive and cannot be delegated": 4	+ 20 Point(s)
The Recycle Bin is not enabled	+ 10 Point(s)
The group Schema Admins is not empty: 1 account(s)	+ 10 Point(s)
Number of admins not in Protected Users: 4	+ 10 Point(s)
Number of admin account with an email address defined: 1	Informative rule
OU without the accidental deletion protection have been found	Informative rule

Analyse détaillée de mes règles "Privileged Accounts"

Dans cette catégorie, j'ai atteint un score de **50 / 100**, ce qui montre que la sécurisation de mes comptes administrateurs est un chantier prioritaire pour mon audit :

- **Absence du flag "Sensitive and cannot be delegated" (+20 points)** : J'ai identifié 4 comptes d'administration qui ne possèdent pas ce flag de sécurité. C'est ma vulnérabilité la plus lourde : sans cette protection, ces comptes sont exposés à des attaques par délégation (comme le "Kerberoasting" ou le relais) qui pourraient permettre à un attaquant de voler leurs privilèges.
- **Corbeille AD non activée (+10 points)** : La corbeille Active Directory n'est pas activée sur mon instance Samba4. Au-delà du risque opérationnel de perte de données, cela complique les investigations numériques (forensics) en cas de compromission et de suppression d'objets par un pirate.
- **Groupe "Schema Admins" non vide (+10 points)** : Un compte est présent dans ce groupe très sensible. Conformément aux bonnes pratiques de durcissement, ce groupe ne devrait contenir des membres que temporairement lors de modifications du schéma, car il offre un contrôle total sur la structure de l'annuaire.
- **Admins absents du groupe "Protected Users" (+10 points)** : J'ai 4 administrateurs qui ne bénéficient pas des protections renforcées du groupe "Protected Users". Ils restent donc vulnérables à des protocoles de chiffrement faibles ou à la mise en cache de leurs hashes sur des postes de travail.

- **Compte admin avec une adresse email définie (Information) :** Un de mes comptes privilégiés possède un attribut email renseigné. C'est une mauvaise pratique d'hygiène car cela facilite l'identification des cibles pour des campagnes de phishing ciblé (Spear Phishing).
- **Unités d'Organisation (OU) sans protection contre la suppression (Information) :** Certaines de mes OU ne sont pas verrouillées contre les suppressions accidentelles. Comme je l'avais noté pour mon lab UCS, c'est un point de remédiation simple à appliquer via les propriétés avancées de l'objet pour stabiliser ma structure.



Analyse détaillée de mes règles "Anomalies"

Dans cette catégorie, j'ai obtenu un score de **35 / 100**, ce qui met en évidence plusieurs points de contrôle de sécurité spécifiques qu'il me reste à configurer ou à durcir :

- **LAPS ne semble pas installé (+15 points) :** C'est mon anomalie la plus coûteuse en points. Sans la solution *Local Administrator Password Solution*, je n'ai pas de gestion automatisée et rotative des mots de passe administrateurs locaux de mes machines, ce qui facilite les attaques par déplacement latéral une fois qu'un poste est compromis.
- **Politique d'audit incomplète sur les contrôleurs de domaine (+10 points) :** PingCastle indique que ma politique d'audit ne collecte pas les événements clés. En cas d'intrusion, je serais incapable de retracer précisément les actions de l'attaquant sur mon annuaire, ce qui est un frein majeur pour la détection et la réponse aux incidents.
- **Nombre de DC trop faible pour la redondance (+5 points) :** Je ne dispose que d'un seul contrôleur de domaine (1 DC). Pour mon lab actuel, c'est normal, mais en

production, cela constitue un point de défaillance unique (SPOF) tant pour la disponibilité que pour la résilience de l'annuaire.

- **Hardened Paths modifiés pour baisser la sécurité (+5 points)** : Des paramètres de chemins sécurisés ont été modifiés, réduisant le niveau de sécurité global. Cela peut exposer le système à des exécutions de scripts malveillants via des chemins réseau non protégés.
- **Absence de politique de mot de passe pour les comptes de service (Information)** : Aucun paramètre n'oblige mes comptes de service à avoir une longueur de mot de passe supérieure ou égale à 20 caractères. C'est une recommandation de durcissement importante pour contrer les attaques par force brute sur ces comptes souvent oubliés.
- **Groupe PreWin2000 contenant "Authenticated Users" (Information)** : Cette configuration historique par défaut dans Samba permet une lecture trop large des attributs de l'annuaire par n'importe quel utilisateur authentifié, facilitant la phase d'énumération pour un attaquant.
- **Protocoles obsolètes (TLS 1.0/1.1 et LLMNR) (Information)** : Au moins un de mes DC utilise encore des protocoles de chiffrement anciens ou laisse activé le protocole de résolution de noms LLMNR. Comme je l'ai vu avec NTLMv1, ces protocoles sont des cibles de choix pour les attaques de type "Man-in-the-Middle".
- **Utilisateurs authentifiés pouvant créer des enregistrements DNS (Information)** : N'importe quel utilisateur du domaine peut ajouter des entrées dans mon DNS. Cela peut être détourné pour effectuer du détournement de trafic ou de l'empoisonnement DNS au sein de mon réseau lab.local.

Synthèse des Recommandations

Pour abaisser mon score de risque global (actuellement à 50) sous la barre des 30, je dois prioriser les actions suivantes :

- **Sécuriser les comptes à hauts privilèges (Priorité Haute)** : Je dois impérativement activer le flag "**Sensitive and cannot be delegated**" sur mes 4 comptes administrateurs pour bloquer les attaques par délégation. Il est également nécessaire de vider le groupe "**Schema Admins**" et d'intégrer les administrateurs au groupe "**Protected Users**" pour renforcer leur protection native.
- **Améliorer l'hygiène du domaine (Stale Objects)** : Ma priorité est de désactiver le support des protocoles **NTLMv1 et LM**, qui sont des failles critiques d'interception. Je dois aussi réduire la valeur du **Machine Account Quota (MAQ)** de 10 à 0 pour empêcher les utilisateurs non-admins d'ajouter des machines au domaine lab.local.
- **Corriger les anomalies techniques** : Je prévois d'installer une solution de type **LAPS** pour gérer les mots de passe locaux et d'activer les **politiques d'audit avancées** sur mon contrôleur de domaine afin de tracer les événements de sécurité clés.
- **Activer les mécanismes de résilience** : Je dois activer la **corbeille Active Directory** (Recycle Bin) pour sécuriser mes objets contre les suppressions accidentelles et verrouiller mes Unités d'Organisation (OU) contre la suppression.

- **Nettoyer les protocoles réseau et DNS** : Il est nécessaire de désactiver via GPO les protocoles obsolètes comme **LLMNR** et **TLS 1.0/1.1**. Je dois également restreindre le droit des utilisateurs authentifiés à créer des enregistrements DNS pour éviter tout empoisonnement du cache.
- **Optimiser la structure AD** : Je dois finaliser la déclaration de mes **sous-réseaux (Subnets)** dans les Sites et Services AD pour garantir une réplication et une localisation des services sans erreurs.